

NISIR BANK S.C.

SETA Employee Training Portal
Security Education, Training & Awareness

INFORMATION SECURITY POLICY

Employee Compliance Obligations & Behavioural Standards

For: All Nisir Bank Employees — Mandatory Policy Acknowledgment Required

Document Reference: NISIR-ISEC-POL-001 | Version: 2.1

Issued by: IT Security & Compliance Department | Nisir Bank S.C., Addis Ababa, Ethiopia

MANDATORY READING

You must read and understand this Information Security Policy before accessing your SETA Portal Internal Mail inbox. After reading, you will complete a short automated Policy Compliance Assessment. This policy document is available as a downloadable resource on the Foundational Learning page of your SETA Portal. The policies in this document are the behavioural standards against which your actions in the Internal Mail system are measured.

Nisir Bank S.C. Information Security Policy

Scope: This policy applies to all employees, Graduate Trainees, contractors, and authorized users of Nisir Bank S.C. information systems and the SETA Employee Training Portal, effective from the date of onboarding. Compliance with this policy is mandatory and non-negotiable.

Regulatory Basis: This policy is issued in accordance with the National Bank of Ethiopia's Cybersecurity Directive 17/2024, the Financial Institutions Information Security Standard, and the Ethiopian Personal Data Protection Proclamation. Non-compliance may result in both internal disciplinary action and regulatory consequences.

Policy 1: Email Security and Suspicious Links

All employees must apply the following rules to every email received in the Nisir Bank SETA Portal Internal Mail inbox and any other bank communication channel:

- Read every email carefully before taking any action. Check the sender's full email address displayed under the sender name in the reading pane — not just the display name shown in the inbox list.
- All legitimate Nisir Bank internal communications originate from @nisirbank.com email addresses. The verified staff directory in your Onboarding Brief lists all authorized internal senders and their email addresses.
- Before clicking any inline link embedded in an email body, hover your mouse over the link and verify that the URL displayed at the bottom of your browser matches nisirbank.com. Any other domain is suspicious.
- Do not click any inline link in an email that: (a) comes from a sender not on the official staff directory, (b) leads to a URL domain other than nisirbank.com, or (c) asks for credentials, personal information, or payment details.
- Do not open or download attachments from unknown or unverified senders.
- Report all suspicious emails to itsecurity@nisirbank.com or via the 'Report Suspicious Threat' button on the Community page of the SETA Portal before taking any action on them.

 **POLICY REQUIREMENT:** The presence of an inline link in an email does not make the email suspicious — legitimate Nisir Bank emails regularly contain inline links to training modules, compliance documents, and HR resources. What matters is WHERE the link leads. Always hover to check the URL before clicking.

Policy 2: SETA Portal Access and Credential Management

The Nisir Bank SETA Portal is the bank's internal platform for security training, compliance management, and internal communications. All access to the portal is governed by the following mandatory rules:

- Access the SETA Portal only from authorised bank workstations. Do not access the portal from personal devices or unsecured networks.
- SETA Portal credential updates — including password changes — are ONLY performed through Account Settings inside the portal directly, or through the IT Security helpdesk in person or via an official helpdesk ticket. Credential management through email links is NEVER authorised under any circumstances.
- If you receive any email — regardless of the apparent sender — asking you to click a link to verify, re-activate, or update your SETA Portal account credentials, this is a phishing attack. Do not click the link. Report it immediately to itsecurity@nisirbank.com.
- Do not share your SETA Portal Employee ID or password with any person — including colleagues, line managers, IT staff, or senior management — under any circumstances.
- Log out of the SETA Portal completely at the end of every session. Do not leave an active portal session unattended.
- Your Employee ID is in the format E-XXXXX (e.g., E-10234). Treat this as confidential information — do not share it unnecessarily or use it as a component of passwords.

 **POLICY REQUIREMENT:** SETA Portal credential re-verification is NEVER conducted through email links or forms. If you receive an email claiming that maintenance, a security update, or any other event requires you to click a link and enter your credentials, it is a phishing attack — regardless of how official it appears.

Policy 3: Password Management

Strong password practices are the primary defence against unauthorised access to bank systems. All employees must comply with the following password requirements:

3.1 Password Requirements

- Minimum 10 characters in length
- Must include at least one uppercase letter (A–Z), one lowercase letter (a–z), one number (0–9), and one special character (@, #, \$, %, !, &)
- Must not contain your full name, Employee ID, date of birth, job title, department name, or any easily guessable personal information
- Must not be the same as any of your last 5 passwords
- Must be changed every 90 days — the SETA Portal system will prompt you when your password is approaching expiry

3.2 Password Protection Rules

- Never share your password with any person under any circumstances — including colleagues, line managers, IT Security staff, or senior management
- Never write your password on paper, sticky notes, or any physical medium left at or near your workstation
- Never store your password in an unencrypted document on your computer or any shared drive

- Never use your Nisir Bank password for any personal or external accounts
- Change your password exclusively through Account Settings inside the SETA Portal — never through an email link
- Lock your workstation immediately when stepping away from your desk (keyboard shortcut: Windows key + L)

Policy 4: External Communications and Regulatory Correspondence

As a bank employee, you may receive communications from external organisations, regulatory bodies, or partner institutions. The following rules govern your response to all external communications:

- All external communications claiming to be from regulatory bodies — including the National Bank of Ethiopia, the Ethiopian Banking Compliance Authority (EBCA), the Financial Intelligence Centre, or any other regulatory institution — that request action via an inline link must be forwarded to compliance@nisirbank.com for verification before any action is taken.
- Do not complete any external survey, form, or information request using your Employee ID, bank credentials, customer information, or personal data unless the Compliance Department has provided written confirmation of legitimacy.
- Official regulatory communications to individual Nisir Bank employees are always coordinated through the Compliance Department. They are never sent directly to individual staff members requiring immediate personal action via external links.
- Verify the email domain of any external communication carefully. The sender's full email address is displayed under their name in the SETA Portal reading pane.
- Never use contact details provided within a suspicious email to verify its legitimacy — always use the official internal directory or contact the Compliance Department directly.

 **POLICY REQUIREMENT:** Emails claiming to be from regulatory bodies that require immediate personal action via an external link — especially those threatening compliance consequences for non-action — are a common phishing technique targeting bank employees. Always forward to compliance@nisirbank.com first.

Policy 5: Social Media, Informal, and Social Communications

Phishing attacks do not always appear in professional formats. Employees must apply the same security standards to informal and social email communications as to formal bank communications:

- Do not click inline links in emails that invite you to view photos, videos, social content, or informal announcements unless: (a) the email comes from a verified @nisirbank.com address on the staff directory, AND (b) you were explicitly expecting such communication.
- All official Nisir Bank staff communications — including social event announcements, staff welfare updates, and team notifications — are sent from @nisirbank.com email

addresses or posted to the Community section of the SETA Portal. Any such communication from a non-@nisirbank.com address is unofficial and should be treated with caution.

- If you receive an informal email with an inline link from a sender whose email address is not an @nisirbank.com address on the staff directory, treat it as suspicious regardless of its casual or friendly tone.
- Do not forward suspicious emails to colleagues — this spreads the threat. Report directly to itsecurity@nisirbank.com.

Policy 6: Customer Data Protection

Nisir Bank employees handle sensitive customer information as part of their daily responsibilities. The following rules govern the handling of all customer data:

- Never share customer account numbers, balances, transaction histories, identity documents, or any other personally identifiable information via email in response to unsolicited requests, regardless of the apparent source.
- All requests for customer data from external parties must be channelled through the Compliance Department following formal inter-bank data sharing protocols.
- Do not access customer accounts you are not explicitly authorised to access, even if you believe it is for a legitimate purpose.
- Do not store customer data on personal devices, personal cloud storage, or any storage media not approved by IT Security.
- Report any actual or suspected customer data exposure immediately to itsecurity@nisirbank.com and compliance@nisirbank.com.

Policy 7: Use of Portable Devices and External Storage

- Do not connect personal USB drives, external hard disks, or any portable storage device to bank computers without explicit prior approval from IT Security.
- USB drives and portable storage provided as part of your official onboarding pack have been pre-approved and cleared by IT Security — these are the only portable storage devices authorized for use.
- Do not transfer confidential bank data or customer information to portable storage devices without IT Security approval and a documented business justification.
- All portable storage media to be used on bank systems must be scanned for malware by IT Security before first use.

Policy 8: Incident Reporting Obligations

Reporting security incidents promptly is one of the most important obligations of every Nisir Bank employee. The bank's no-blame reporting culture is designed to remove barriers to immediate reporting:

- Any employee who suspects they have been targeted by a phishing attack, social engineering attempt, or any other security threat must report it immediately to itsecurity@nisirbank.com and their line manager — within the same working session.

- Any employee who accidentally interacted with a suspicious email — including clicking an inline link or entering information on a suspicious page — must report it immediately, even if no apparent harm has resulted.
- Employees who report security incidents in good faith are explicitly protected from disciplinary action under this policy, regardless of the outcome of the incident.
- Knowingly failing to report a security incident that an employee is aware of is a disciplinary offense under the bank's Code of Conduct.
- You may also use the 'Report Suspicious Threat' button on the Community page of the SETA Portal to report suspicious emails or threats.

Reporting Channel	Contact Details
IT Security Helpdesk (Primary)	itsecurity@nisirbank.com Extension 2200
Compliance Department	compliance@nisirbank.com Extension 2201
Human Resources	hr@nisirbank.com Extension 2100
SETA Portal Community Page	'Report Suspicious Threat' button — available 24/7

EMPLOYEE ACKNOWLEDGMENT

By accessing the Nisir Bank SETA Portal Internal Mail inbox, I confirm that I have read and understood this Information Security Policy in full and agree to comply with all policies stated herein during my use of the bank's systems.

Information Security Policy — Scenario-Based Compliance Check

This assessment presents five realistic scenarios based on the policies you have just read. Each scenario corresponds directly to a situation you may encounter in the Nisir Bank SETA Portal Internal Mail inbox. Select the response that correctly follows Nisir Bank's Information Security Policy. The system will immediately show whether your response is policy-compliant and explain which specific policy applies.

Assessment Details

Scenarios: 5 | Format: Policy scenario multiple choice | Feedback: Immediate — identifies which policy applies and why | Purpose: Confirms you understand the specific rules governing the Internal Mail inbox before you begin

NOTE: The three phishing scenarios in this assessment (Scenarios 1, 2, and 3) reflect the types of situations you will encounter in your Internal Mail inbox. Understanding the correct policy response now prepares you to handle them correctly during the session.

Scenario 1 [Policy 1 — Email Security (ties to Email #8)]

You receive the following email in your Nisir Bank SETA Portal inbox:

*'Subject: URGENT: Your SETA Portal Account Requires Re-Verification
From: Natnael Worku — IT Systems <natnael.worku@nisirbank-it.com>*

Following recent portal maintenance, your account requires immediate re-verification. Please enter your Employee ID and password in the form below within 24 hours or your access will be suspended.'

According to Nisir Bank's Information Security Policy, what is the CORRECT response?

Option	Response Choice	Policy Feedback (shown on selection)
A	Enter your Employee ID and password in the form provided to avoid losing portal access.	✗ INCORRECT — POLICY VIOLATION <i>This violates Policy 1 (Email and Suspicious Links) and Policy 2 (SETA Portal Access). SETA Portal credential re-verification is NEVER conducted through an email form or link. The sender domain (nisirbank-it.com) also does not match the official nisirbank.com domain — a clear indicator of a spoofed address.</i>
B	Reply to the email asking Natnael to confirm the request is genuine before proceeding.	✗ INCORRECT — POLICY VIOLATION <i>Replying to this email contacts the attacker at nisirbank-it.com, not the real Natnael Worku. Policy 6 (Incident Reporting) requires you to report suspicious emails immediately — not engage with them.</i>
C	Do not interact with the form or any links. Check the sender email domain (nisirbank-it.com ≠ nisirbank.com). Report the email immediately to itsecurity@nisirbank.com and contact the IT helpdesk directly through official channels to verify whether any action is genuinely required.	✓ CORRECT — POLICY COMPLIANT <i>Correct. This response follows Policy 1 (do not click links in suspicious emails), Policy 2 (portal credentials are only updated through official IT helpdesk channels — never via email forms), and Policy 6 (report suspicious emails immediately). The mismatched sender domain</i>

		is the key indicator that this is an impersonation attack.
D	Forward the email to a colleague to ask if they received the same message before deciding what to do.	✗ INCORRECT — POLICY VIOLATION Forwarding a phishing email risks spreading the threat to colleagues. Policy 6 requires immediate reporting to itsecurity@nisirbank.com — not informal consultation with colleagues.

Scenario 2 [Policy 1 & Policy 4 — External Communications (ties to Email #14)]

You receive the following email in your Nisir Bank SETA Portal inbox:

'Subject: ACTION REQUIRED: EBCA Staff Awareness Survey — Closes Friday
From: EBCA Compliance Team <survey@ebca-ethiopia.org>

The Ethiopian Banking Compliance Authority requires all Nisir Bank employees to complete a mandatory staff awareness survey via the link below by Friday. Non-completion will be reported to your Compliance Officer and may affect your bank's regulatory standing. You will be asked to provide your Employee ID and bank name.'

According to Nisir Bank's Information Security Policy, what is the CORRECT response?

Op tio n	Response Choice	Policy Feedback (shown on selection)
A	Click the link and complete the survey immediately — it is from a regulatory authority and non-compliance has serious consequences.	✗ INCORRECT — POLICY VIOLATION This violates Policy 4 (External Communications). Legitimate regulatory communications to individual employees are always coordinated through Nisir Bank's Compliance Department. The sender domain (ebca-ethiopia.org) is external and unverified. The urgency and threat of regulatory consequences are manipulation tactics typical of regulatory impersonation phishing.
B	Forward the email to compliance@nisirbank.com for verification before taking any action.	✓ CORRECT — POLICY COMPLIANT Correct. Policy 4 explicitly states that all external emails requesting action via a link must be forwarded to the Compliance Department (compliance@nisirbank.com) for verification before any response. Official regulatory communications are coordinated through the Compliance Department — they are never sent directly to individual employees requiring immediate personal action via external links.
C	Complete the survey but do not enter your Employee ID — only provide your bank name.	✗ INCORRECT — POLICY VIOLATION Accessing an unverified external link violates Policy 1 regardless of what information you enter. The link click itself is the policy violation — it can expose your device to malware or confirm your identity to the attacker. Always verify through the Compliance Department before any interaction with external links.
D	Search online for the EBCA website and complete the survey directly from their official site.	✗ INCORRECT — POLICY VIOLATION While this shows good instinct, independent action bypasses the mandatory verification process. Policy 4 requires all external regulatory communications to be forwarded to compliance@nisirbank.com for verification —

		not handled independently by individual employees, however well-intentioned.
--	--	--

Scenario 3 [Policy 1 & Policy 5 — Informal Communications (ties to Email #19)]

You receive the following email in your Nisir Bank SETA Portal inbox:

'Subject: You Have to See These! Team Day Photos from Last Friday 📸🎉
From: Nisir Bank Staff Association <staffassociation.nisir@gmail.com>

Hey everyone! We have uploaded ALL the photos from last Friday's team day to an online album. Click the link below to view and download your favorites — no login required, just click and enjoy!

The sender (staffassociation.nisir@gmail.com) is not listed in your staff directory. According to Nisir Bank's Information Security Policy, what is the CORRECT response?

Op tio n	Response Choice	Policy Feedback (shown on selection)
A	Click the link — the content is just photos and poses no security risk.	✗ INCORRECT — POLICY VIOLATION This violates Policy 1 (Email and Suspicious Links) and Policy 5 (Informal and Social Communications). The content a phishing link claims to show is irrelevant — what matters is where the link actually leads. The Gmail sender address and absence from the staff directory are both policy-level warning signs that this email must not be acted on.
B	Reply to the sender asking them to confirm they are a Nisir Bank employee before clicking the link.	✗ INCORRECT — POLICY VIOLATION Replying to this email contacts whoever controls the Gmail account — which may be an attacker. Policy 6 requires reporting to IT Security — not engaging with the sender of a suspicious email. Use official internal channels to verify any staff welfare communications.
C	The sender (staffassociation.nisir@gmail.com) uses a Gmail address — not an official @nisirbank.com address — and is not on the staff directory. Do not click the link. Report the email to itsecurity@nisirbank.com as a suspicious communication.	✓ CORRECT — POLICY COMPLIANT Correct. Policy 1 requires checking sender email domains before taking any action. Policy 5 explicitly states that all official Nisir Bank staff communications — including social announcements — are sent from @nisirbank.com addresses or posted through official portal channels. A Gmail sender not on the staff directory is a clear policy violation indicator. Report immediately.
D	Forward the email to HR to ask if there was a staff event last Friday before deciding whether to click.	✗ INCORRECT — POLICY VIOLATION While verifying through HR is a good instinct, forwarding a potentially malicious email risks spreading the threat. The correct action is to report to IT Security (itsecurity@nisirbank.com) first, then verify with HR through a separate official channel without forwarding the suspicious email.

Scenario 4 [Policy 2 — SETA Portal Access Rules]

Which of the following correctly states Nisir Bank's policy on SETA Portal credential management?

Op	Response Choice	Policy Feedback (shown on selection)
----	-----------------	--------------------------------------

Option		
A	Employees may update their portal credentials by clicking a link in an official-looking email from IT Security, provided the email is addressed to them by name.	✗ INCORRECT — POLICY VIOLATION <i>This is incorrect regardless of how official the email appears or whether it uses your name. Policy 2 is absolute: portal credential updates are ONLY performed through Account Settings inside the portal directly, or through the IT helpdesk in person/via official helpdesk tickets. There are NO exceptions.</i>
B	Portal credentials may be shared with a trusted colleague in an emergency, provided the colleague changes the password back immediately after use.	✗ INCORRECT — POLICY VIOLATION <i>Policy 2 prohibits credential sharing under all circumstances with no exceptions. 'Trusted colleague' and 'emergency' are not exceptions recognized by policy. IT Security has emergency access procedures that do not require credential sharing.</i>
C	Employees must change their portal password every 90 days through Account Settings inside the portal. Credential re-verification is never conducted through email links. Credentials must never be shared with any person.	✓ CORRECT — POLICY COMPLIANT <i>Correct. This statement accurately reflects three core requirements of Policy 2: the 90-day password rotation requirement, the prohibition on credential management through email links, and the absolute prohibition on credential sharing. All three apply without exception.</i>
D	Employees should click any link in an IT Security email that asks for credential verification, as these links are secured by the bank's own IT infrastructure.	✗ INCORRECT — POLICY VIOLATION <i>No email link — regardless of the apparent sender — is an authorised method for SETA Portal credential verification at Nisir Bank. IT Security will never send such a link. Any email claiming otherwise is a phishing attack.</i>

Scenario 5 [Policy 3 & Policy 6 — Password Management and Reporting]

You accidentally entered your Employee ID and password into a form linked from a suspicious email 10 minutes ago, before realising it was likely a phishing attack. You are worried about disciplinary consequences. According to Nisir Bank policy, what must you do?

Option	Response Choice	Policy Feedback (shown on selection)
A	Change your password immediately and do not report the incident — no harm may have occurred and reporting could lead to disciplinary action.	✗ INCORRECT — POLICY VIOLATION <i>This response violates Policy 6 (Incident Reporting). Knowingly failing to report a suspected security incident IS a disciplinary offense. Conversely, reporting in good faith is explicitly protected under the no-blame policy. Changing your password alone is insufficient — IT Security needs to investigate and may need to take additional protective action.</i>
B	Wait to see if your account shows signs of unauthorized access before reporting — you want to be sure something actually happened before raising an alarm.	✗ INCORRECT — POLICY VIOLATION <i>Policy 6 requires immediate reporting of suspected incidents — not evidence-based reporting after damage has occurred. In banking environments, minutes of unauthorized access can cause significant harm. The no-blame policy removes the barrier to immediate reporting.</i>
C	Report immediately to itsecurity@nisirbank.com and your line manager, explain exactly what happened including what information you entered	✓ CORRECT — POLICY COMPLIANT <i>Correct. Policy 6 requires immediate reporting of all suspected security incidents. The no-</i>

	and when, and follow IT Security's instructions. You are protected under the no-blame reporting policy.	<i>blame policy explicitly protects employees who report in good faith — regardless of the severity of the incident or what information was shared. IT Security can immediately reset your credentials, monitor for unauthorized access, and investigate the phishing source to protect other employees.</i>
D	Report it only if the phishing email also targeted your colleagues — a single incident may not warrant escalation.	✗ INCORRECT — POLICY VIOLATION <i>Every suspected security incident must be reported regardless of scope. A single compromised employee credential can be the entry point for a much larger attack on the bank's systems. Policy 6 makes no exception for 'isolated' incidents.</i>

Policy Assessment complete. Your responses have been recorded. You may now access the Internal Mail inbox.

Nisir Bank S.C. | IT Security & Compliance Department | itsecurity@nisirbank.com | Extension 2200